MSM ACADEMY

SECTION 4

Lead Implementer
Implementation methodology



4.1 The implementation journey
4.2 Initiating the project
4.3 Understanding the starting point
4.4 Designing the ISMS
4.5 Implementing and operating
4.6 Checking readiness
4.7 Practical tips and pitfalls

MSM ACADEMY

SECTION 4 · LESSON 4.1

The implementation journey

4.1

From first meeting to certification readiness

LESSON 4.1

What implementing an ISMS means

Two stages, one goal

1. A project establishes the ISMS: context, scope, risk, controls, documents, people.
2. Normal operation then runs it: processes produce records, audits and reviews follow.
3. The standard says what must exist, not in which order to build it.

The MSM six-phase methodology

1	**Initiate**	Commitment, charter, governance, resources	Phase 1
2	**Understand**	Context, scope, starting point, gap analysis	Phase 2
3	**Design**	Risk method, risk assessment and treatment, SoA, document design	Phase 3
4	**Implement**	Controls by priority, documents, awareness, records	Phase 4
5	**Check**	Go-live, measures, first internal audit	Phase 5
6	**Ready**	Management review, corrections, readiness, handover	Phase 6

LESSON 4.1

Phases, outputs and where the course goes deeper

Phase	Key outputs	Taught in depth
1 Initiate	Charter, governance, commitment decisions	S4, S2
2 Understand	Context, scope, gap analysis and plan	S5
3 Design	Risk method, risk register, treatment plan, SoA	S6, S7
4 Implement	Controls, documents, awareness, records	S3, S7
5 Check	Measures, first internal audit	S8
6 Ready	Management review, readiness, certification body	S9

LESSON 4.1

Roles in an ISMS project

Role	What they contribute
Top management	Commitment, resources, objectives, risk acceptance authority, management review
ISMS manager	Day-to-day ownership of the ISMS, inside the organization
Lead Implementer or consultant	Method, expertise, facilitation, quality of outputs
Risk and process owners	Decisions on their risks and controls; running the processes
Internal auditor	Independent check that the ISMS conforms and works

LESSON 4.1

How long does it take?

No standard duration, but predictable drivers

- Scope: how many sites, services, people and systems are included
- Starting maturity: how much already works and only needs to be owned and measured
- Resources and decision speed, and any external deadline

The journey: two perspectives

Implementer's view

- Plan by phases and outputs, not by clause number
- Say clearly which method is yours
- Plan for the system to run, not just to exist

Auditor's view

- Look for a system that operates, not a finished project
- Expect records from real operation
- Ask who owns the ISMS once the project ends

LESSON 4.1 · RECAP

Lesson 4.1 recap

- A project establishes the ISMS; operation then runs it
- Six MSM phases: Initiate, Understand, Design, Implement, Check, Ready
- Five roles; only the consultant leaves
- Duration depends on scope, maturity and resources

LESSON 4.1 · KNOWLEDGE CHECK

Check your understanding

A client asks which implementation sequence ISO/IEC 27001 requires. What is the most accurate answer?

A Clause order 4 to 10 is the required sequence

B Plan-Do-Check-Act is the required sequence

C None: the standard sets requirements, and the organization chooses its method

D Annex A order is the required sequence

Check your understanding

A client asks which implementation sequence ISO/IEC 27001 requires. What is the most accurate answer?

A. Clause order 4 to 10 is the required sequence

B. Plan-Do-Check-Act is the required sequence

C. **None: the standard sets requirements, and the organization chooses its method**

D. Annex A order is the required sequence

Answer: C

ISO/IEC 27001 states that clause order does not imply implementation order. A method, such as MSM's six phases, is the implementer's choice.

MSM ACADEMY

SECTION 4 · LESSON 4.2

Initiating the project

Phase 1: Initiate



LESSON 4.2

Why organizations implement an ISMS

The trigger shapes the plan

- Contracts and customers: certification as a condition of business
- Regulation and legal duties: protection of personal data and records
- Risk: an incident or near-miss that exposed real weaknesses
- Assurance: proving to boards, investors and partners that risk is managed

LESSON 4.2

Two different scopes

Do not confuse them

- Project scope: the work to be done, by whom, by when
- ISMS scope (4.3): the boundaries and applicability of the management system
- Decide the ISMS scope early, but only after context and interested parties

LESSON 4.2

Securing leadership commitment

Decisions top management must own from day one

- Why the organization is doing this, and what success means
- Resources: people, time, budget
- Who owns the ISMS, and who may accept which risks

LESSON 4.2

The project charter

Element	What it fixes
Objectives	Why, and what success looks like
Scope and deliverables	The work, and the outputs of each phase
Roles and governance	Sponsor, ISMS manager, steering group, decision rules
Resources and timeline	People, budget, milestones, the target date
Risks to the project	What could stop it, and the response

LESSON 4.2

Project governance

Decide how decisions get made

- A steering group with top management, meeting on a fixed cadence
- A decision log: what was decided, by whom, when
- Escalation rules for blocked decisions and resource conflicts

LESSON 4.2

Resourcing realistically

Resources are a requirement, not a favour

- Internal time from owners, not only from the ISMS manager
- External expertise where it is genuinely missing
- Tools only after the process is understood

LESSON 4.2 · EXERCISE

Exercise: the first priorities

Quenvale, Month 0. About 420 staff, three sites and production in a public cloud. Strong engineering practice; scattered policies; no risk method, objectives, management review or internal audit. Enterprise prospects require certification within 12 months of contract. The CEO asks for “all the policies written by next month”.

List the first five outputs, in order, before documents are written or controls selected.



Pause the video

Then compare with the model answer.

Model answer: the first priorities

1 Commitment	Sponsor decisions and a charter: objectives, resources, governance, target date
2 Scope	Context, interested parties, climate determination, then a draft ISMS scope
3 Starting point	Maturity and gap assessment, crediting what already works
4 Risk method	Risk criteria and method, before any control is chosen
5 Plan	An implementation plan with owners and milestones; documents follow it



Policies follow decisions. Writing them first creates documents nobody owns.

Initiation: two perspectives

Implementer's view

- Get the sponsor’s decisions in writing early
- Separate project scope from ISMS scope
- Set up governance before the first deliverable

Auditor's view

- Look for early leadership decisions in the record
- Check the scope considered 4.1 and 4.2
- Ask how blocked decisions were escalated

Lesson 4.2 recap

- Know the trigger: it shapes the plan
- Keep project scope and ISMS scope apart
- Commitment, charter and governance come first
- Policies follow decisions

LESSON 4.2 · KNOWLEDGE CHECK

Check your understanding

A sponsor wants to buy an ISMS software tool in week one, before scope or risk method are agreed. What is the best advice?

A Wait: agree the process and scope first, then choose a tool that fits

B Buy it: tools speed up every implementation

C Buy it, then design the ISMS around the tool

D Refuse: tools are not allowed in certified ISMSs

Check your understanding

A sponsor wants to buy an ISMS software tool in week one, before scope or risk method are agreed. What is the best advice?

A **Wait: agree the process and scope first, then choose a tool that fits**

B Buy it: tools speed up every implementation

C Buy it, then design the ISMS around the tool

D Refuse: tools are not allowed in certified ISMSs

Answer: A

Tools support a process; they do not define it. Choosing one before scope and method are agreed risks fitting the ISMS to the tool.

MSM ACADEMY

SECTION 4 · LESSON 4.3

Understanding the starting point

4.3

Phase 2: Understand

LESSON 4.3

Context before controls

The first analytical outputs

- External and internal issues, including whether climate change is relevant (4.1)
- Interested parties, their requirements, and which the ISMS addresses (4.2)
- A scope that considers both, and every interface (4.3)

LESSON 4.3

Assessing current maturity

Three ways to find out what is really there

- Interviews: how work is actually done, and who decides
- Document review: what exists, who owns it, how current it is
- Observation and sampling: whether practice matches what people say

LESSON 4.3

Quenvale at Month 0: what works and what is missing

Area	Already works	Fragmented or missing
Identity and access	SSO with MFA for all staff	Access reviews only when someone remembers
Engineering	Code review, scanning, annual penetration test	Threat modelling not linked to company risk
Monitoring	24/7 managed detection and response	No link to customer notification decisions
Governance	CTO and CFO sponsor security spending	No objectives, management review or internal audit

LESSON 4.3

Gap analysis as a phase

Purpose and outputs here; the method in Section 5

- Compares current practice with every requirement and selected control
- Produces findings and a prioritized action plan
- Becomes the baseline for measuring implementation progress

LESSON 4.3

Build on what already works

Mature practice is an asset, not a problem

- Keep what works; give it an owner, a measure and a link to risk
- Document it as it is actually done, not as a template says
- Replace practice only where it fails a requirement or a risk

Role play: “We already do security”



Sunita Rao Head of Engineering

“We already review code, scan every build and pay for a penetration test. Why do we need all this ISMS paperwork?”

YOU

Your move: Explain what changes for her team and what does not. What do you say?

LESSON 4.3 · ROLE PLAY

One way to say it

“You’re right, and we’ll keep all of it. What changes is that it gets an owner, a few measures, and a link to the company’s risks, so it counts as evidence. Your team won’t rewrite what works.”

Why it works

- Agrees first, because she is right
- Names what stays, before what changes
- Turns “paperwork” into ownership, measures and evidence

Starting point: two perspectives

Implementer's view

- Assess with interviews, documents and sampling
- Credit mature practice and bring it into the system
- Let the gap analysis set priorities

Auditor's view

- Test whether existing practice is now owned and measured
- Look for practice documented as it is really done
- Check that priorities came from the gap analysis

LESSON 4.3 · RECAP

Lesson 4.3 recap

- Context, interested parties and scope come before controls
- Assess maturity from three sources
- Gap analysis sets the baseline and priorities (Section 5)
- Build on what works; replace only what fails

Check your understanding

An implementer proposes rewriting every existing engineering procedure into a standard template, although the procedures work well. What is the main weakness?

A None: consistent templates are required by 7.5

B It is only a cost issue for the client

C The standard forbids changing existing procedures

D It replaces working practice without a requirement or risk reason

Check your understanding

An implementer proposes rewriting every existing engineering procedure into a standard template, although the procedures work well. What is the main weakness?

A. None: consistent templates are required by 7.5

B. It is only a cost issue for the client

C. The standard forbids changing existing procedures

D. It replaces working practice without a requirement or risk reason

Answer: D

Working practice should be kept and brought into the ISMS. Rewriting it without a requirement or risk reason adds cost and risk, and 7.5 does not demand templates.

MSM ACADEMY

SECTION 4 · LESSON 4.4

Designing the ISMS

Phase 3: Design

4.4

LESSON 4.4

Three design decisions

Decide before anyone writes

1. The risk method and criteria (6.1.2)
2. The documentation architecture: what is documented, at what level (7.5)
3. How ISMS processes fit existing business processes (5.1 b)

LESSON 4.4

Risk method first

Controls follow risks, so the method comes first

- Risk criteria, including who may accept which levels (6.1.2 a)
- A method that gives consistent, comparable results (6.1.2 b)
- Assessment, treatment and SoA follow, in Section 6

LESSON 4.4

Proportionate documentation

Required, plus what is genuinely necessary

- What the standard requires, as you saw in Section 2
- What the organization decides it needs to be effective (7.5.1 b)
- Toolkits help, but are tailored, not adopted wholesale (Section 7)

LESSON 4.4

Integrating into business processes

Security inside the work, not beside it

- Security steps added to existing processes: hiring, procurement, change, release
- Existing meetings and reports reused for ISMS reviews where possible
- Owners stay the business owners, not the security team

LESSON 4.4

Integrated management systems

When the organization already has other ISO systems

- The harmonized structure gives shared clauses and common terms
- Policy, objectives, audit, review and corrective action can be shared
- Each standard’s specific requirements still have to be met

From design to implementation plan

1	**Workstreams**	Group actions: governance, risk, controls, documents, people
2	**Owners**	One accountable owner for each action
3	**Dates**	Realistic milestones tied to the target date
4	**Dependencies**	What must finish before what can start
5	**Measures**	How progress will be tracked and reported

Design: two perspectives

Implementer's view

- Settle method, architecture and integration first
- Tailor toolkits to the organization
- Plan with owners, dates and dependencies

Auditor's view

- Check design choices are applied consistently
- Look for documents that match real practice
- Ask how ISMS processes fit business processes

LESSON 4.4 · RECAP

Lesson 4.4 recap

- Three design decisions before writing
- Risk method first, because controls follow risks
- Documentation proportionate and tailored
- Integrate into existing processes; plan with owners and dates

Check your understanding

An organization certified to ISO 9001 wants to “reuse its QMS” for ISO/IEC 27001. What is the best assessment?

A It can reuse everything; the structures are identical

B It can share common processes, but must add information security risk assessment, treatment and the SoA

C It cannot integrate; the standards must be kept separate

D It needs only Annex A on top of its QMS

Check your understanding

An organization certified to ISO 9001 wants to “reuse its QMS” for ISO/IEC 27001. What is the best assessment?

A. It can reuse everything; the structures are identical

B. It can share common processes, but must add information security risk assessment, treatment and the SoA

C. It cannot integrate; the standards must be kept separate

D. It needs only Annex A on top of its QMS

Answer: B

Shared structure allows common processes to be integrated, but information security risk assessment, treatment and the SoA are specific requirements that must be added.

MSM ACADEMY

SECTION 4 · LESSON 4.5

Implementing and operating

4.5

Phase 4: Implement

LESSON 4.5

Implementing controls by priority

The treatment plan sets the order

- Highest risks and quickest wins first, as the treatment plan sets out
- Not Annex A order, and not the easiest documents first
- Track each action against the plan and report to the steering group

LESSON 4.5

Awareness, training and communication

Roll out by audience, not by email blast

- Everyone: policy, their contribution, how to report (7.3, 6.8)
- Specific roles: deeper training where competence is needed (7.2)
- Managers: what they must ask of their teams (Annex A 5.4)

LESSON 4.5

Records as a by-product

Design evidence into the work

- Approvals, reviews and checks recorded where the work happens
- Tools that log automatically wherever possible
- No parallel “evidence folders” filled before an audit

LESSON 4.5

Measuring from day one

A few meaningful measures, not a dashboard of everything

- Choose measures that show whether key processes and controls work (9.1)
- Define method, timing and owner for each
- Start collecting at go-live, so trends exist by the first review

LESSON 4.5

Managing change during the project

The organization keeps changing while you build

- Changes to the ISMS itself are planned (6.3)
- Changes to systems and processes are controlled (8.1, Annex A 8.32)
- Scope changes go back through 4.3 and the risk assessment

Role play: “Can’t you just write it all?”



Rafael Moreira Head of Information Security

“You’ve done this many times. Can’t you just write all the policies and run the ISMS for us until the audit?”

YOU

Your move: Keep ownership with Quenvale without refusing to help. What do you say?

LESSON 4.5 · ROLE PLAY

One way to say it

“I’ll draft and guide every step, so it’s fast. But you and the owners make the decisions and run the processes, because the auditor will ask you, not me, and you’ll run it long after I’ve gone.”

Why it works

- Offers real help: drafting and guidance
- Explains why ownership must stay inside
- Uses the audit as a practical reason, not a rule

Implementation: two perspectives

Implementer's view

- Follow the treatment plan, not Annex A order
- Design records into the work
- Measure from go-live

Auditor's view

- Sample records, not plans
- Ask people how they do the work
- Look for trends, not single numbers

LESSON 4.5 · RECAP

Lesson 4.5 recap

- The treatment plan sets the order
- Awareness and training by audience
- Records as a by-product; measures from day one
- Changes during the project are planned and controlled

Check your understanding

Two weeks before the certification audit, a team creates an “evidence folder” by recreating approval records from memory. What is the main problem?

A. None: evidence only has to exist at the audit

B. It is only a 7.5 formatting issue

C. Recreated records do not show the process ran, and misrepresent what happened

D. It is acceptable if the manager signs each record

Check your understanding

Two weeks before the certification audit, a team creates an “evidence folder” by recreating approval records from memory. What is the main problem?

A. None: evidence only has to exist at the audit

B. It is only a 7.5 formatting issue

C. **Recreated records do not show the process ran, and misrepresent what happened**

D. It is acceptable if the manager signs each record

Answer: C

Records must come from the process actually running. Recreated records do not show that, and presenting them as original misrepresents what happened.

MSM ACADEMY

SECTION 4 · LESSON 4.6

Checking readiness

Phases 5 and 6: Check and Ready

4.6

LESSON 4.6

The first internal audit

The organization’s own check, before anyone else’s

- Covers the ISMS against the standard and the organization’s own rules (9.2)
- Auditors objective and impartial: not auditing their own work
- Findings treated through corrective action; method in Section 8

LESSON 4.6

The first management review

Top management looks at the evidence and decides

- Every 9.3.2 input considered: actions, changes, performance, audit results, risks
- Decisions recorded on improvement and changes to the ISMS (9.3.3)
- Often the clearest single proof of leadership at certification

LESSON 4.6

Acting on findings before certification

Show the system corrects itself

- Correct the instance; remove the cause where needed (10.2)
- Check that corrective actions worked
- Open actions are acceptable if planned, owned and progressing

LESSON 4.6

Readiness criteria

Area	Ready when
Scope and context	Documented, justified, and reflected in the risk assessment
Risk and SoA	Assessment done, treatment plan approved by owners, SoA complete
Operation	Processes running and producing records for a meaningful period
Internal audit	Completed across the ISMS, findings being treated
Management review	Held with all required inputs, decisions recorded

LESSON 4.6

Engaging a certification body

At a glance; the detail is in Section 9

- Choose an accredited certification body, early enough to plan Stage 1
- Agree scope and timing; prepare the documented ISMS for Stage 1
- The certification body decides; the consultant cannot certify

Readiness: two perspectives

Implementer's view

- Plan internal audit early enough to act on it
- Give top management a full, honest review
- Use the readiness criteria, not the calendar

Auditor's view

- Has the system run long enough to judge?
- Were internal audit findings acted on?
- Did management review make real decisions?

LESSON 4.6 · RECAP

Lesson 4.6 recap

- First internal audit by objective auditors, early enough to act
- First management review with all inputs and recorded decisions
- Correct findings and check effectiveness
- Ready by criteria; the certification body decides

Check your understanding

The consultant who built a client’s ISMS offers to perform its first internal audit to save time. What is the best response?

A Decline: auditing your own work undermines objectivity and impartiality (9.2.2 b)

B Accept: the consultant knows the system best

C Accept, if the audit report is signed by top management

D Accept, as long as the certification body is told

Check your understanding

The consultant who built a client’s ISMS offers to perform its first internal audit to save time. What is the best response?

- **A** **Decline: auditing your own work undermines objectivity and impartiality (9.2.2 b)**
- **B** Accept: the consultant knows the system best
- **C** Accept, if the audit report is signed by top management
- **D** Accept, as long as the certification body is told

Answer: A

Clause 9.2.2 b) requires objectivity and impartiality. Someone auditing what they built cannot provide it, however well they know it.

MSM ACADEMY

SECTION 4 · LESSON 4.7

Practical tips and pitfalls

What experience teaches

4.7

LESSON 4.7

Common pitfalls (1 of 2)

Pitfall	What to do instead
Documentation first	Decisions and design first; documents follow
Consultant-owned ISMS	Owners decide and run; the consultant enables
Generic templates	Tailor to how the organization really works
Scope too wide or too narrow	Scope from context, risks and interfaces
6.1.1 ignored	Address risks and opportunities for the ISMS itself

LESSON 4.7

Common pitfalls (2 of 2)

Pitfall	What to do instead
Controls picked from the Annex A list	Controls chosen because risks need them
No measures	A few meaningful measures from go-live
Late internal audit	Audit early enough to correct findings
Review without decisions	Record decisions on improvement and change
Evidence created for the audit	Records produced by the work itself

LESSON 4.7

Scaling for small organizations

Same requirements, lighter means

- Fewer, shorter documents; combined roles
- Compensating controls where duties cannot be separated (Annex A 5.3)
- Internal audit by an external party or a peer arrangement

LESSON 4.7

Consultant conduct and independence

Advise and enable, within clear boundaries

- Advise, draft and facilitate; never take the client’s decisions
- Never audit your own work, internally or for certification
- Be open about any conflict of interest

LESSON 4.7

Handing over

Leave a system the organization can run without you

- Owners can explain and run every process without help
- Open items listed with owners and dates
- Measures, audits and reviews scheduled into the year ahead

Practice: two perspectives

Implementer's view

- Leave a system, not a library
- Keep decisions with the client
- Scale the means, not the requirements

Auditor's view

- Ask people, not the consultant
- Look for decisions made inside the organization
- Check the ISMS kept running after handover

LESSON 4.7 · RECAP

Lesson 4.7 recap

- Ten common pitfalls, each with a better alternative
- Small organizations: same requirements, lighter means
- Consultants advise and enable; they never audit their own work
- A good handover leaves no dependency

Check your understanding

Three months after certification, a client’s ISMS manager leaves. Nobody else can explain the risk assessment or run the internal audit programme. What was the implementation’s main weakness?

A The certification body should have detected it

B Too few documents were written

C The internal audit was too short

D Ownership and capability were not spread to the organization’s people

Check your understanding

Three months after certification, a client’s ISMS manager leaves. Nobody else can explain the risk assessment or run the internal audit programme. What was the implementation’s main weakness?

A. The certification body should have detected it

B. Too few documents were written

C. The internal audit was too short

D. Ownership and capability were not spread to the organization’s people

Answer: D

A sound implementation spreads ownership and capability across owners, so the ISMS survives any one person leaving.

SECTION 4 · SUMMARY

The methodology in one view

- Initiate and Understand: commitment, scope and starting point
- Design: risk method, documentation, integration, plan
- Implement and Check: controls by priority, records, measures, internal audit
- Ready: management review, corrections, readiness, handover

MSM ACADEMY

SECTION 4 COMPLETE

Next: Section 5

ISMS gap analysis

